Cloud Platform Deep Dive M2·W2



Networking & Security

Recap



Compute, Storage, IAM, Costs…

IAM controls who can act; networking controls what can reach what. Both are least privilege, applied at different layers.

Networking is notorious for being one of the most frustrating parts of tech because it relies on layers of abstract logic, confusing math, and a massive wall of acronyms (VPC, CIDR, NAT, DNS, ACL).



The good news is that you don't need to memorise all the math to use it. Think of networking like the plumbing in a house. You don't need to be a master hydraulic engineer to know that turning on the tap makes water flow, or that a drain keeps dirty water away. In the cloud, the provider (like AWS or Google Cloud) handles all the physical "pipes and wires." Your only job is to draw the blueprint of where the walls go.

VPC and Subnetting

What is a VPC?

A VPC (Virtual Private Cloud) is a securely isolated, private network hosted within a public cloud provider's infrastructure (such as Amazon Web Services or Google Cloud). It lets you run your code, store data, and host websites in a dedicated environment where your traffic is completely separate from other cloud users.

AWS is not the only cloud provider that uses the term **VPC**. Because it has become the standard industry term for an isolated, private network in the public cloud, most major cloud providers use the exact same name.

Again, a VPC is like your own private, isolated network inside the cloud.

Analogy: a gated estate. Nobody gets in unless you build a gate and give them a pass.

Subnetting

Subnetting is the process of splitting a single large network into smaller, isolated sub-networks, which are called subnets.

If a VPC is a massive office building, subnets are the individual rooms or floors inside that building.

Why do we need subnets?

If you put thousands of computers on one single network without subnets, it causes massive problems:

1. Security Risks: Every computer could talk to and see every other computer. A hacker breaching a public web server would instantly have access to your private payroll database.

2. Traffic Jams: Computers constantly shout out "broadcast" messages to find each other. In a massive network, this background noise slows the whole system down.

Note: You cannot create a subnet without using CIDR notation. Simply put, a subnet is the physical or logical group of devices, while CIDR is the mathematical language used to define that group's size and boundaries.

Public & Private Subnets

In cloud environments, subnets are primarily used to enforce security boundaries. We generally divide them into two types:

• Public Subnets (The Front Lobby): Connected directly to the internet. This is where you put resources that the public needs to see, like your company website or an e-commerce storefront.

• Private Subnets (The Back Vault): Completely cut off from the public internet(No inbound access from the internet). This is where you hide your backend databases, customer records, and proprietary source code.

A subnet is “public” only because its route table has a route to an Internet Gateway. Nothing else makes it public. A private subnet has no such route.

QQ: Why not put everything public? What’s the cost of a mistake?

We will learn more about subnetting, subnet masks and cidr notations in the coming weeks.

CIDR: Classless Inter-Domain Routing

The CIDR is a standardised method used to allocate IP addresses and route internet traffic efficiently.

A CIDR address looks like a standard IP address followed by a forward slash and a number. E.g. 10.0.0.0/24

This format is split into two distinct parts:

1. The Base IP (**10.0.0.0**): This indicates the starting point of the network block.

2. The Routing Prefix (**/24**): Also called the "subnet mask" or "CIDR suffix," this number tells you how many bits of the 32-bit IP address are frozen (fixed) for the network identity. The remaining bits are left free for individual device (host) IP addresses.

The Prefix Rule: Smaller Suffix = More IPs

Because IP addresses use binary code (base-2 math), every time the CIDR suffix decreases by 1, the total number of available IP addresses doubles.

• /32 = 1 IP address (All 32 bits are locked. Used to target one specific machine).

• /24 = 256 IP addresses (Common size for standard cloud subnets).

• /16 = 65,536 IP addresses (Common size for an entire AWS or GCP VPC network).

• /8 = 16,777,216 IP addresses (Massive corporate or ISP networks).

Core AWS Networking Components

Region and Availability Zone (AZ): As discussed earlier, A region is a geographic area (e.g. `eu-west-1`). An AZ is one or more data centres inside it (`eu-west-1a`). A VPC lives in one region and spans all its AZs. A subnet lives in exactly one AZ. Spreading resources across AZs protects against a data centre failing.

Route table: A set of rules. For instance, “traffic going to X, send it to Y.” Every subnet is associated with one. The built-in `local` route (`10.0.0.0/16 → local`) lets everything inside the VPC talk to each other. Add `0.0.0.0/0 → igw-xxx` and the subnet becomes public. Note that `0.0.0.0/0` means “any address not matched by a more specific route.”

Internet Gateway (IGW): The two-way door between your VPC and the internet basically acting as the border control. It’s attached to the VPC, free, and highly available. The request from the user hits the IGW, which in turn passes it into the VPC. An instance also needs a public IP to use an IGW. The IGW translates between the instance’s private IP and its public IP.

NAT Gateway: Lets instances in a private subnet reach out to the internet (patches, APIs) without being reachable from it. Placed in a public subnet, with an Elastic IP. If a database in the Private Subnet needs to download a software update from the internet, it sends traffic out through the NAT Gateway (placed in the Public Subnet). Then the NAT Gateway masks the private IP, grabs the update, and passes it back, ensuring the internet can never initiate a direct connection to that private database.The private route table sends `0.0.0.0/0 → nat-xxx`. **Costs hourly plus per GB, so it’s the most common lab cost trap.**

Elastic IP (EIP): A static public IPv4 address you own until you release it. Normal public IPs change when an instance stops and starts; an EIP doesn’t. AWS charges for public IPv4 addresses, and idle EIPs especially, so release them if not in use.

Elastic Network Interface (ENI):A virtual network card attached to an instance, holding its private IP, MAC address, and security groups.

Network ACLs vs Security Groups

A security group is a virtual firewall at the **instance** level.

- Stateful: if inbound traffic is allowed, the reply is automatically allowed
- Allow rules only: there's no deny
- Default: all inbound blocked, all outbound allowed
- Rules can use an IP range or another security group as the source, which is the best least-privilege pattern (e.g. "DB accepts 3306 only from the web SG")

A Network Access Control List (NACL) is a firewall at the **subnet** level.

- Stateless: you must allow traffic in both directions, including ephemeral return ports (1024-65535)
- Allow and deny rules, evaluated by rule number from lowest, first match wins
- The default NACL allows everything; a custom one denies everything until you add rules
- Use it as a coarse outer layer, e.g. blocking a known bad IP range. Security groups do the day-to-day work.

Comparing NACLs vs Security Groups

In comparison, the NACL is the estate gate guard, checking everyone entering the estate while the security group is the lock on each flat's door.

Stateful vs stateless in plain words: With a stateful firewall, if you allowed a request in, the reply goes out automatically. A stateless firewall treats the reply as a brand-new request, so you must write a rule for it.

Example rules slide:

- Web SG: allow 80/443 from anywhere, allow 22 from your IP only
- DB SG: allow 3306 from the web SG only (not from an IP range)

	NACL	Security Group
Applies to	Subnet	Instance (network interface)
State	Stateless (must allow both directions)	Stateful (return traffic auto-allowed)
Rules	Allow and deny	Allow only
Evaluation	In number order, first match wins	All rules together
Default	Default NACL allows all	Deny all inbound, allow all outbound

Other AWS Networking Components

- **VPC Endpoints:** Let private resources reach AWS services (like S3 or DynamoDB) without going through the internet or a NAT gateway. Gateway endpoints (S3, DynamoDB) are free; interface endpoints (powered by PrivateLink) cost money. It is a great cost and security win e.g Your private instance reads from S3 without leaving AWS's network.
- **Elastic Load Balancer (ELB):** Spreads traffic across multiple instances. The Application Load Balancer (ALB) works at layer 7 (HTTP) and routes by path or host; the Network Load Balancer (NLB) works at layer 4 (TCP/UDP) for speed.
- **Route 53:** AWS DNS service. E.g. Translates `app.example.com` into an IP or load balancer, and can do health checks and routing policies.
- **VPC Peering:** A private connection between two VPCs so they can talk using private IPs. Non-transitive (A↔B and B↔C does not mean A↔C), and CIDRs must not overlap.
- **Transit Gateway:** A central hub connecting many VPCs and on-premises networks. Solves the peering mesh problem at scale.
- **VPN and Direct Connect:** Ways to connect your office or data centre to AWS. Site-to-Site VPN goes over the internet encrypted while Direct Connect is a dedicated physical line.
- **VPC Flow Logs:** Records of accepted and rejected traffic to and from network interfaces. The best tool for answering "why is my traffic being blocked?"
- **Bastion host / Session Manager:** A bastion is a hardened public VM used as a jump box. Session Manager (via SSM) is a modern alternative that gives shell access with no open SSH port at all.

Setting up a Bastion Host: Lab

A **Bastion Host** (or Jump Box) acts as a secure transit hub. Instead of exposing your sensitive private servers to the public internet, you expose exactly *one* hardened machine.

1. **Network Setup:** Create a VPC with at least one Public Subnet (with an Internet Gateway route) and one Private Subnet (no internet route).

2. **Deploy Instances:**

    • Launch your target server (e.g., Database) into the Private Subnet. Ensure it has no Public IP.

    • Launch your Bastion VM into the Public Subnet. Assign it a Public IP.

3. **Configure Bastion Security Group (The Outer Wall):**

    • Add an Inbound Rule for Port 22 (SSH) or Port 3389 (RDP).

    • Crucial: Set the Source to your specific corporate or home IP address (e.g., 203.0.113.50/32). Never use 0.0.0.0/0.

4. **Configure Private Server Security Group (The Inner Wall):**

    • Add an Inbound Rule for Port 22 or 3389.

    • Crucial: Set the Source to the Private IP address or Security Group ID of the Bastion Host. This completely blocks the rest of the world.

5. **Test Connectivity:** Connect from your laptop to the Bastion, then jump from the Bastion to your private server.

How a request travels typically.

A user opens your website, which sits in a public subnet:

1. DNS (Route 53) resolves the domain to your public IP or load balancer
2. The request reaches the Internet Gateway
3. The IGW forwards it to the instance's private IP, subject to NACL
4. The NACL checks the subnet's inbound rules
5. The security group checks the instance's inbound rules
6. The instance receives the request and replies (the SG automatically allows this; the stateless NACL needs an explicit outbound rule)
7. The reply goes back out via the route table and IGW

For a private instance running `apt update`:

1. Instance sends traffic to the internet
2. Private route table: `0.0.0.0/0 → NAT gateway`
3. NAT gateway (in the public subnet) forwards it via the IGW using its Elastic IP
4. The response returns the same way; nobody outside can initiate a connection in

Questions?

QQs

1. What makes a subnet “public”?
2. Difference between a security group and a NACL?
3. Why does the private instance need a NAT gateway to run `apt update`?
4. Why is `0.0.0.0/0` on port 22 dangerous?
5. What does “stateful” mean?